



Tomee Key

Specyfikacja techniczna
sprzętowy klucz bezpieczeństwa FIDO2

Tomee Manager

Tomee Key • nr 3F2A0C1D5B6E7F8091A2B3C4 • firmware 0.14.4

Zidentyfikuj klucz

Klucz Kody PIN Passkeys SSH Firmware Reset

Firmware: 0.14.4

Wersja bezpieczeństwa: 6

Numer seryjny: 3F2A0C1D5B6E7F8091A2B3C4

AAGUID: 5e334bdf94624ff99e369ba9a0bf9891

Standardy: FIDO_2_0, FIDO_2_1_PRE, FIDO_2_1

PIN: ustawiony, pozostało prób: 8

Passkeys: widoczne po odblokowaniu PIN-em w zakładce Passkeys

☒ Uruchamiaj Tomee Managera razem z Windows (w tle, przy zegarze)

Aplikacja w tle ustawia kluczowi czas po każdym połączeniu — dzięki temu kody wpisywane dotykem działają bez otwierania okna.

Tomee Key to sprzętowy klucz bezpieczeństwa USB zgodny z FIDO2 (WebAuthn, CTAP 2.1), z generatorem kodów jednorazowych TOTP/HOTP i obsługą kluczy SSH. Ten dokument opisuje funkcje, parametry i architekturę bezpieczeństwa urządzenia oraz aplikacji Tomee Manager.

Program pilotażowy. Specyfikacja dotyczy serii testowej. Parametry wersji produkcyjnej mogą się różnić — ograniczenia serii pilotażowej zebrano w rozdziale [Status i plan rozwoju](#).

Dotyczy: firmware 0.14.4 i 0.15.0 (z izolacją TrustZone) · Tomee Manager 0.4.0 · październik 2026

Spis treści

1	Przegląd	8	Kody jednorazowe
2	Zgodność ze standardami	9	Aktualizacje oprogramowania
3	Kryptografia	10	Tomee Manager
4	Architektura bezpieczeństwa	11	Zgodność z systemami
5	Sprzęt	12	Status i plan rozwoju
6	Interfejs USB	13	Kontakt
7	Pamięć i pojemność		

1 Przegląd

Typ urządzenia	sprzętowy klucz bezpieczeństwa USB (roaming authenticator)
Uwierzytelnianie	FIDO2 / WebAuthn — passkeys, logowanie bez hasła i drugi składnik
Kody jednorazowe	TOTP i HOTP, wpisywane automatycznie gestem dotykowym
SSH	klucze OpenSSH <code>sk-ecdsa-sha2-nistp256@openssh.com</code> , także rezydentne
Ochrona dostępu	PIN 4–63 znaki, potwierdzenie obecności dotykiem
Kryptografia	ECDSA i ECDH P-256 oraz AES-256 w akceleratorach sprzętowych, sprzętowy generator liczb losowych
Połączenie	USB 2.0 Full Speed, klasa HID — bez sterowników
Zarządzanie	Tomee Manager dla Windows, bez uprawnień administratora
Aktualizacje	podpisane cyfrowo, instalowane przez internet, z ochroną przed cofnięciem wersji

2 Zgodność ze standardami

FIDO2 / CTAP

Parametr	Wartość
Wersje protokołu	FIDO_2_0 , FIDO_2_1_PRE , FIDO_2_1
Transport	USB HID (CTAPHID)
Algorytm podpisu	ES256 (ECDSA P-256 z SHA-256, COSE -7)
Protokoły PIN/UV	2 i 1
Opcje	rk , up , clientPin , pinUvAuthToken , credMgmt , credentialMgmtPreview , makeCredUvNotRqd
Rozszerzenia	hmac-secret , credProtect (poziomy 1–3)
Komendy CTAP 2	makeCredential, getAssertion, getNextAssertion, getInfo, clientPIN, reset, credentialManagement, selection
Uprawnienia tokenu PIN	mc (rejestracja), ga (logowanie), cm (zarządzanie kontami)
Atestacja	format packed , samopodpisana (self attestation)
Maksymalny rozmiar komunikatu	7609 bajtów
Lista dozwolonych kont	do 16 pozycji na zapytanie
Identyfikator konta (credential ID)	49 bajtów (limit zgłaszany: 128)

Pozostałe standardy

Standard	Zakres
RFC 6238 (TOTP)	kody czasowe, HMAC-SHA-1 i HMAC-SHA-256, 6 lub 8 cyfr
RFC 4226 (HOTP)	kody licznikowe, licznik przechowywany w kluczu
Format otpauth://	import kont w Tomee Manager (tekst kodu QR)
OpenSSH 8.2+ (FIDO)	klucze sk-ecdsa , opcje resident i verify-required
USB HID 1.11	trzy interfejsy HID, w tym klawiatura w trybie boot

3 Kryptografia

Algorytm	Zastosowanie	Realizacja
ECDSA P-256	podpisy logowania i rejestracji, atestacja	sprzętowo — akcelerator PKA
ECDH P-256	uzgodnienie klucza w protokołach PIN 1 i 2	sprzętowo — akcelerator PKA
AES-256-CBC	szyfrowanie PIN-u i sekretów hmac-secret w transporcie	sprzętowo — moduł AES
SHA-256, HMAC-SHA-256	skrót, wyprowadzanie kluczy, uwierzytelnianie identyfikatorów kont	programowo
HKDF-SHA-256	wyprowadzanie kluczy w protokole PIN 2	programowo
HMAC-SHA-1	kody TOTP/HOTP (zgodność z RFC 4226/6238)	programowo
Generator liczb losowych	klucz urządzenia, identyfikatory kont, klucze sesji	sprzętowo — TRNG

4 Architektura bezpieczeństwa

Klucz urządzenia. Przy pierwszym uruchomieniu generator TRNG tworzy 256-bitowy tajny klucz urządzenia. Z niego wyprowadzane są osobne klucze do tworzenia kluczy prywatnych kont, uwierzytelniania identyfikatorów kont i rozszerzenia hmac-secret. Klucz urządzenia nigdy nie opuszcza Tomee Key; reset go wymienia, co unieważnia wszystkie konta.

Klucze prywatne kont. Każde konto ma własny klucz prywatny P-256, wyprowadzany z klucza urządzenia, skrótu domeny serwisu i jednorazowej wartości losowej. Serwis przechowuje 49-bajtowy identyfikator konta, uwierzytelniony kodem HMAC — zmodyfikowany lub obcy identyfikator jest odrzucany. Klucz prywatny istnieje w pamięci RAM tylko na czas podpisu i jest potem zerowany.

Powiązanie z domeną. Podpis obejmuje skrót identyfikatora serwisu (RP ID), więc podpis uzyskany na fałszywej stronie nie jest ważny w prawdziwym serwisie (ochrona przed phishingiem).

PIN

- przesyłany do klucza wyłącznie w postaci zaszyfrowanej (protokół PIN 1 lub 2);
- klucz przechowuje tylko skrót SHA-256 PIN-u, nie sam PIN;
- 3 błędne próby z rzędu wymagają ponownego podłączenia klucza, 8 błędnych prób blokuje PIN do resetu;
- licznik prób jest zapisywany w pamięci trwałej przed sprawdzeniem PIN-u, więc odłączenie klucza go nie zeruje;
- token PIN wygasa po 60 s bezczynności i najpóźniej po 10 minutach.

Obecność użytkownika. Rejestracja, logowanie, reset i aktualizacja wymagają dotknięcia klucza (limit 30 s). Reset do ustawień fabrycznych jest możliwy tylko w ciągu 10 s od podłączenia i po dotknięciu.

Czujnik dotyku. Pojemnościowe pole z kalibracją przy starcie i śledzeniem dryfu otoczenia. Palec, który leżał na polu przed żądaniem, musi się najpierw oderwać — dopiero kolejne dotknięcie potwierdza operację. „Dotyk” trwający ponad 10 s (kropla wody, oparty przedmiot) powoduje ponowną kalibrację i jest ignorowany. Szum

czujnika w pomiarach na prototypie: $\sigma \approx 1,5$ jednostki przy progu ok. 350 i sygnale dotyku 600–3000 (także mokrym palcem).

Ochrona kont. Rozszerzenie credProtect ukrywa wybrane konta przed osobą, która nie zna PIN-u. Konta rezydentne (passkeys) są widoczne i zarządzalne tylko po podaniu PIN-u.

Rozdzielenie interfejsów. Tomee Manager komunikuje się z kluczem przez osobny interfejs zarządzania. Interfejs ten odrzuca rejestrację i logowanie, a tokeny PIN wydaje tylko z uprawnieniem zarządzania kontami. Dzięki temu aplikacja działa bez uprawnień administratora, a przejęty proces aplikacji nie może logować się do serwisów.

Kody jednorazowe. Sekrety kont są zapisywane w kluczu i nie ma polecenia, które by je odczytało — klucz zwraca wyłącznie gotowe kody. Dodawanie, usuwanie i zmiana gestów wymagają PIN-u, jeśli jest ustawiony.

Wpisywanie kodów. Interfejs klawiatury wysyła wyłącznie cyfry kodu i opcjonalnie klawisz Enter, tylko po geście wykonanym na kluczu. Przytrzymanie wpisuje kod dopiero po puszczeniu palca, a gesty są wstrzymane przez 1 s po uruchomieniu i po błędzie czujnika.

Pamięć trwała. Konta, kody, PIN i licznik podpisów są zapisywane w sposób odporny na zanik zasilania — przerwany zapis nie uszkadza wcześniej zapisanych danych, a zamiana rekordu przerwana wyjęciem klucza jest dokańczana przy następnym uruchomieniu, więc kod HOTP nigdy nie jest wydany dwa razy. Klucz nie rozpoczyna zapisu, gdy napięcie zasilania spada poniżej ok. 2,8 V (detektor PVD). Testy: 30 wyjęć klucza w trakcie zapisu kodów (3586 zapisów) i 15 w trakcie zapisu passkeys (929 zamian) — bez utraty ani zdublowania danych.

Ochrona oprogramowania przed zapisem. Każdy zapis i kasowanie pamięci Flash jest sprawdzany pod kątem zakresu; aplikacja przy starcie blokuje dla siebie obszar bootloadera i własnego obrazu, więc żaden błąd osiągalny przez USB nie może ich zmienić. Aktualizację instaluje wyłącznie bootloader, po sprawdzeniu podpisu.

5 Sprzęt

Parametr	Wartość
Mikrokontroler	STMicroelectronics STM32L562CET6
Rdzeń	Arm Cortex-M33 (architektura Armv8-M z TrustZone)
Pamięć	512 KB Flash (dwa banki), 256 KB SRAM
Akceleratory	PKA (kryptografia klucza publicznego), AES, TRNG
Obsługa	pojemnościowe pole dotykowe (kontroler TSC)
Sygnalizacja	dwie diody LED: czerwona i zielona
Zasilanie	z portu USB
Złącze serwisowe	SWD — wyłącznie do produkcji i serwisu
Wymiary, obudowa, złącze USB	zostaną podane dla wersji produkcyjnej

6 Interfejs USB

Parametr	Wartość
Standard	USB 2.0 Full Speed (12 Mb/s), urządzenie złożone
Sterowniki	niewymagane (klasa HID, sterowniki systemowe)
Interfejs 0 — FIDO	HID, usage page 0xF1D0, CTAPHID
Interfejs 1 — Tomee Management	HID, usage page 0xFF00 (vendor), CTAPHID; dostępny bez uprawnień administratora w Windows
Interfejs 2 — klawiatura	HID boot keyboard; wpisywanie kodów jednorazowych
Komendy CTAPHID	INIT, PING, WINK, CBOR, CANCEL, KEEPALIVE, ERROR
Identyfikatory VID/PID	tymczasowe (seria pilotażowa)

7 Pamięć i pojemność

Dane	Pojemność
Passkeys (konta rezydentne, w tym klucze SSH rezydentne)	100
Konta nierezydentne (klucze bezpieczeństwa, SSH bez resident)	bez limitu — nie zajmują pamięci klucza
Konta z kodami jednorazowymi	56
Nazwa użytkownika i nazwa wyświetlana passkey	do 64 bajtów każda
Nazwa konta z kodami	do 64 bajtów
Sekret konta z kodami	do 64 bajtów
Licznik podpisów	globalny, 32-bitowy, trwały

Dane użytkownika (konta, kody, PIN) są zachowywane przy aktualizacjach firmware.

8 Kody jednorazowe

Parametr	Wartość
Typy	TOTP (czasowe), HOTP (licznikowe)
Algorytmy	HMAC-SHA-1, HMAC-SHA-256
Długość kodu	6 lub 8 cyfr
Okres TOTP	1–3600 s (w Tomee Manager: 10–300 s, domyślnie 30 s)

Parametr	Wartość
Wymóg dotknięcia	opcjonalny, dla każdego konta osobno
Gesty	1, 2 lub 3 dotknięcia oraz przytrzymanie — po jednym koncie na gest
Przytrzymanie	1,5–5 s, kod wpisywany po puszczeniu (szybkie miganie zielonej diody); dłuższe nic nie wpisuje
Powtórzenie kodu	4 dotknięcia wpisują ostatni kod ponownie (przez 90 s)
Zatwierdzenie	opcjonalny klawisz Enter po kodzie
Źródło czasu	Tomee Manager ustawia czas przy każdym podłączeniu; klucz odmierza go dalej z taktów magistrali USB

9 Aktualizacje oprogramowania

Parametr	Wartość
Architektura	bootloader (32 KB) + aplikacja w osobnym obszarze pamięci
Format obrazu	nagłówek z podpisem ECDSA P-256, skrótem SHA-256 i wersją bezpieczeństwa
Weryfikacja	podpis i skrót sprawdzane przed instalacją i przy każdym uruchomieniu — w bootloadrze od 0.14.4 dwukrotnie, z losowym odstępem (odporność na zakłócenia)
Nieudana instalacja	gdy instalacja nie może się rozpocząć, klucz uruchamia dotychczasowy firmware i ponawia próbę przy kolejnym starcie
Ochrona przed cofnięciem wersji	klucz odrzuca obraz z niższą wersją bezpieczeństwa niż zainstalowana
Instalacja	obraz trafia najpierw do obszaru tymczasowego (do 176 KB), kopiowanie po pełnej weryfikacji
Potwierdzenie	dotknięcie klucza przed rozpoczęciem aktualizacji
Kanały	Tomee Manager (automatyczne sprawdzanie) lub plik <code>.bin</code> wybrany ręcznie
Dystrybucja	github.com/crawe1/tomeekey-pub z sumami SHA-256

10 Tomee Manager

Funkcja	Opis
Informacje o kluczu	numer seryjny, wersje firmware i bezpieczeństwa, stan PIN-u, identyfikacja klucza diodami
PIN	ustawienie i zmiana
Passkeys	lista kont, zmiana nazwy, usuwanie

Funkcja	Opis
Kody	dodawanie kont (otpauth:// lub ręcznie), kopiowanie kodów, przypisywanie gestów
SSH	tworzenie kluczy, eksport klucza publicznego, odtwarzanie kluczy rezydentnych na nowym komputerze
Firmware	sprawdzanie, pobieranie i instalacja aktualizacji
Reset	przywrócenie ustawień fabrycznych
Praca w tle	ikona w zasobniku systemowym, autostart, ustawianie czasu klucza
Samoaktualizacja	pobieranie nowych wersji aplikacji

Wymaganie	Wartość
System	Windows 10 lub 11, 64-bit
Instalacja	niewymagana — pojedynczy plik .exe
Uprawnienia	zwykłego użytkownika (bez administratora)

11 Zgodność z systemami

Klucz korzysta ze standardowych sterowników HID i interfejsu WebAuthn, dlatego powinien działać wszędzie, gdzie obsługiwane są klucze FIDO2 przez USB.

Środowisko	Status
Windows 11 — przeglądarka z WebAuthn (passkeys, PIN)	przetestowane
Windows 11 — OpenSSH (sk-ecdsa)	przetestowane
Windows 10	oczekiwana zgodność (OpenSSH wymaga wersji 8.9+)
macOS, Linux — przeglądarki z WebAuthn	oczekiwana zgodność, bez Tomee Manager
Android (USB-C / OTG)	oczekiwana zgodność

12 Status i plan rozwoju

Seria pilotażowa ma następujące ograniczenia:

- brak certyfikacji FIDO Alliance;
- sprzętowa blokada odczytu pamięci (RDP) nie jest włączona — osoba z fizycznym dostępem i specjalistycznym sprzętem mogłaby odczytać zawartość klucza;
- atestacja samopodpisana, bez certyfikatu producenta; identyfikator modelu (AAGUID) prototypowy;
- brak obsługi starszego protokołu U2F (CTAP 1);
- tymczasowe identyfikatory USB;

- klucz nie ma własnego zegara — kody TOTP wpisywane gestem wymagają działającego Tomee Managera;
- aplikacja Tomee Manager nie jest jeszcze podpisana cyfrowo (ostrzeżenie Windows SmartScreen).

Planowane w wersji produkcyjnej: włączenie blokady odczytu pamięci, atestacja z certyfikatem producenta, obsługa U2F, certyfikacja FIDO oraz podpisana cyfrowo aplikacja.

Izolacja TrustZone — od firmware 0.15.0 (5 października 2026). Klucze serii pilotażowej dostają ją przy przygotowaniu, a klucze już używane przechodzą na nią z zachowaniem danych. Mikrokontroler dzieli pamięć i kod na strefę bezpieczną i zwykłą; kod strefy zwykłej (obsługa USB i poleceń) nie ma dostępu do danych strefy bezpiecznej, nawet gdyby zawierał błąd:

Etap	Zakres	Stan
1	bootloader i weryfikacja podpisu firmware w strefie bezpiecznej	zakończony
2	klucz urządzenia, klucze prywatne kont i podpisy w strefie bezpiecznej — aplikacja dostaje tylko gotowe podpisy	zakończony
3	PIN, licznik prób, token PIN i rozszerzenie hmac-secret w strefie bezpiecznej	zakończony
4	sekrety kodów jednorazowych w strefie bezpiecznej — po dodaniu konta aplikacja przechowuje tylko zaszyfrowany sekret i nie ma klucza, by go odczytać	zakończony
5	aktualizacje strefy bezpiecznej przez USB (podpisane, z osobną wersją bezpieczeństwa)	zakończony
5b	ochrona zapisu i ukrycie części startowej po uruchomieniu	zakończony
5c	blokada odczytu pamięci z izolacją TrustZone (sprawdzona na egzemplarzu testowym; włączana przy produkcji)	zakończony
6	przeniesienie danych kluczy już używanych (konta, PIN, kody) do nowej wersji	zakończony

Każdy etap przechodzi pełny zestaw testów (FIDO2, PIN, passkeys, kody, gesty, aktualizacje, wyjmowanie klucza w trakcie zapisu, testy losowymi danymi). Po każdym etapie i po przeniesieniu danych dotychczasowe konta, PIN, passkeys i kody działały bez zmian.

13 Kontakt

Pytania techniczne i zgłoszenia: biuro@tomee.pl. Instrukcja użytkownika, aplikacja i firmware: github.com/crawe1/tomeekey-pub.